GRC Assistant

Project Team

Hadia Tariq 21I-1907
Israr Ahmed 21I-1902
Burhan Ud Din 21i-1558

Session 2021-2025

Supervised by

Mr Abdullah Abid

Co-Supervised by

None

Department of Cyber Security

National University of Computer and Emerging Sciences
Islamabad, Pakistan

June, 2025

Contents

List of Figures

List of Tables

Chapter 1

Introduction

This document specifies the scope our tool, "GRC Assistant" will cover and how this project would be divided into different parts for the successful completion of the tool.This tool is basically intended to streamline the process of auditing by reducing manual effort, enhancing security and ensuring real-time monitoring of compliance. The intended audience of this document includes the developers as this document will help them understand the flow of our project as this document will provide a clear blue print of the system's architecture, requirements and functionalities.This document will give developers an understanding of what needs to e made, reducing any sort of ambiguity. Moreover, this document can also be used by marketing teams to get a better understanding of the product's key features and benefits which will help them in their promotion to the target audience. [1].

1.1 Problem Statement

Manual compliance auditing process stems a lot of inefficiencies.To cater those inefficiencies we are developing this web based tool that will reduce the manual effort and reduce any chances of risks that manual process might have.Traditional compliance auditing specially based on ISO standards are time-consuming, prone to human error and often lack consistency.Moreover,most of the organizations face very large amount of variety of data, handling which can be labor-intensive and costly.Furthermore, existing solutions for auditing face difficulties in integration with other tools, requiring specialised knowledge and do not even provide full automation. Keeping all these problems in mind, our software aims to automate the auditing process, reducing manual effort to a huge extent which improves accuracy.By using technologies like Natural Language Processing (NLP) for analysing documents, making agents for real time monitoring of data usage within the company and managing a database for every kind of data, the system enables the organi-

zations to meet regulatory compliance with ease and accuracy.This solution is beneficial for organizations using standards such as ISO and organizations dealing with large amount of data providing them with a streamed-line and cost effective way to mitigate risk and enhance operational efficiency.

1.2 Scope

This project encompasses the development of a web based tool which will automate the auditing process on ISO standards.The system streamlines the auditing process by automating document analysis,data collection,log tracking and generation of reports.s.The primary goal of our tool is to cater the limitations of traditional auditing by using technologies such as Natural Language Processing(NLP), real-time monitoring, and automated data collection.Our solution also provides features like user authentication,database management and integration with third party tools for enhanced interoperability. The project will involve a we-based platform for administrators ensuring flexibility and usability across various platforms.Our system will also be scalable to support organizations of various sizes and industries.Moreover, it can be used for auditing with respect to other standards such as GDPR and NIST upon some changes.Additionally, the system will offer real-time dashboards, visual analytics, and notifications for proactive compliance management. The boundaries of our project are clearly defined to focus on automating the auditing process, without including direct system security management.The tool will cater to organizations all over the world who work on ISO standards specifically with easy deployment and usage with minimal technical expertise.Overall, this tool aims to help organizations by offering a cost-effective, user-friendly solution that enhances security and compliance practices.

1.3 Modules

The modules of our project are as follows:

1.3.1 Database And Back End Integration

This module handles the communication between the front end and the database.Moreover, it also stores all compliance related data including audit logs,user information and compliance reports. Our tool integrates Firebase as our database allowing real time update and easy usage.

1. Ensures secure data storage and retrieval safeguarding sensitive information against

data breaches.

2. Uses API keys to ensure safe and real time data exchange between the front userinterface and back-end services.

1.3.2 Agent Creation

We will create our own agents for real time log collection, scanning of network and generating reports.This module ensures the working of system on its own and provide monitoring of compliance task.

1. Enables easy and scalable deployment of agents across different network environments.

2. Agents continuously monitor and collect data related to compliance, ensuring upto-date information for audits.

1.3.3 Web Module

The web module provides users with an intuitive platform to interact with the system. This module ensures smooth user interaction with essential features and functionalities.

1. A comprehensive dashboard that displays compliance status, alerts, and recent activities.

2. Allows users to create, manage, and track compliance-related projects and tasks through an intuitive interface.

1.4 User Classes and Characteristics

The various user classes who will use this product, and their characteristics are as follows:

1. Introduction

User class	Description
Auditor	Auditors will use the system to conduct compliance assessment,track policy adherence and generate compliance reports.They need access to basic functionalities such as data processing features, network information, compliance documents and report generating functionalities.

Admin	Admin officers are responsible for managing the platform’s user data as well as to check the security situation of the company by looking into the reports generated by the tool.
Risk Mitigation Team	The risk mitigation team will look into the report generated by our tool to asses the risks reported by GRC Assistant to take actions to mitigate risks inside the company.
Developer	Developers will interact wit the system to add new features to our tool such as training our tool to some other standards such as GDPR and NIST.Moreover, developers will also interact with the system to fix bugs and provide technical support.

User Classes and Characteristics For GRC Assistant

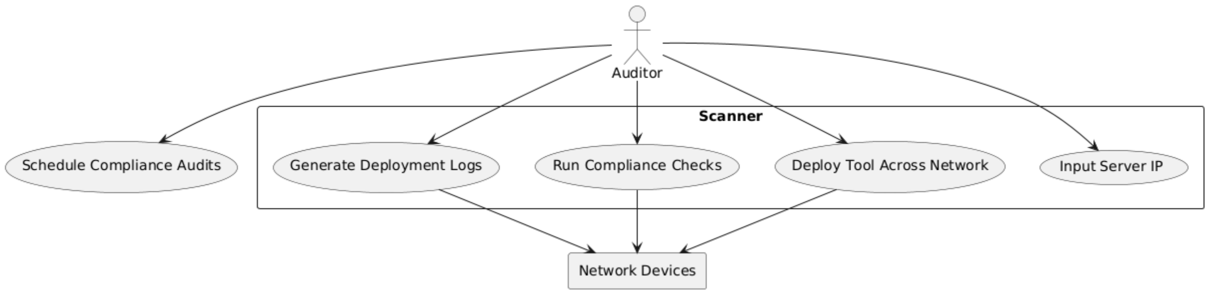
Chapter 2

Project Requirements

This chapter describes the functional and non-functional requirements of the project.

2.1 Use-case/Event Response Table/Storyboarding

The use case diagram of our project is as follows:



2.2 Functional Requirements

The functional requirements of our project are given below:

2.2.1 Real Time Compliance Monitoring

Following are the requirements for module 1:

1. The system shall continuously monitor network traffic and any activity happening within an organization in real time.

2. The system will generate alerts in real time if it detects any sort of deviation from the normal flow.

2.2.2 Automation Of Network Compliance

Following are the requirements for module 2:

1. The system shall use NLP for automation of data extraction from the policy of the organization.
2. The system shall automatically conduct compliance audits on the basis of preconfigured ISO 27001 standards and generate comprehensive audit reports.

2.2.3 Dashboard And Reporting

Following are the requirements for module 3:

1. The system will provide a dashboard that will give an overview of compliance reports, risk levels and recent activities.
2. The system will generate report on the basis of user-selected criteria such as compliance results and audits results.

2.2.4 Notifications And Alerts

Following are the requirements for module 4:

1. The system shall send alerts when it detects any kind of compliance related issues.
2. The system shall send alerts if any security issue is faced such as unauthorised access.

2.2.5 User Management

Following are the requirements for module 5:

1. The system shall allow the users to enter through google, Facebook or linked-in.
2. The system will implement role based access control and the roles can be deleted, modified and created by admin permissions.

2.3 Non-Functional Requirements

The non-functional requirements of our project are:

2.3.1 Reliability

Our system ensures high level of reliability and smooth operation with minimum amount of downtime. Reliability is measured in mean time between failures (MTBF), with a clear reason of failure such as system crash or data corruption. In case of failures, the system will have automatic recovery mechanism.

2.3.2 Usability

Usability requirements ensure that the system is easy to learn and use and helping users to avoid errors and facilitates efficient interaction. This system will provide ease to the users and will get user feedback regularly. Example:

USE-1: The system shall enable users to generate compliance reports with single click avoiding repetitive tasks done manually. USE-2: The system will have good user interface letting the people have an easy access and usage of tool.

2.3.3 Performance

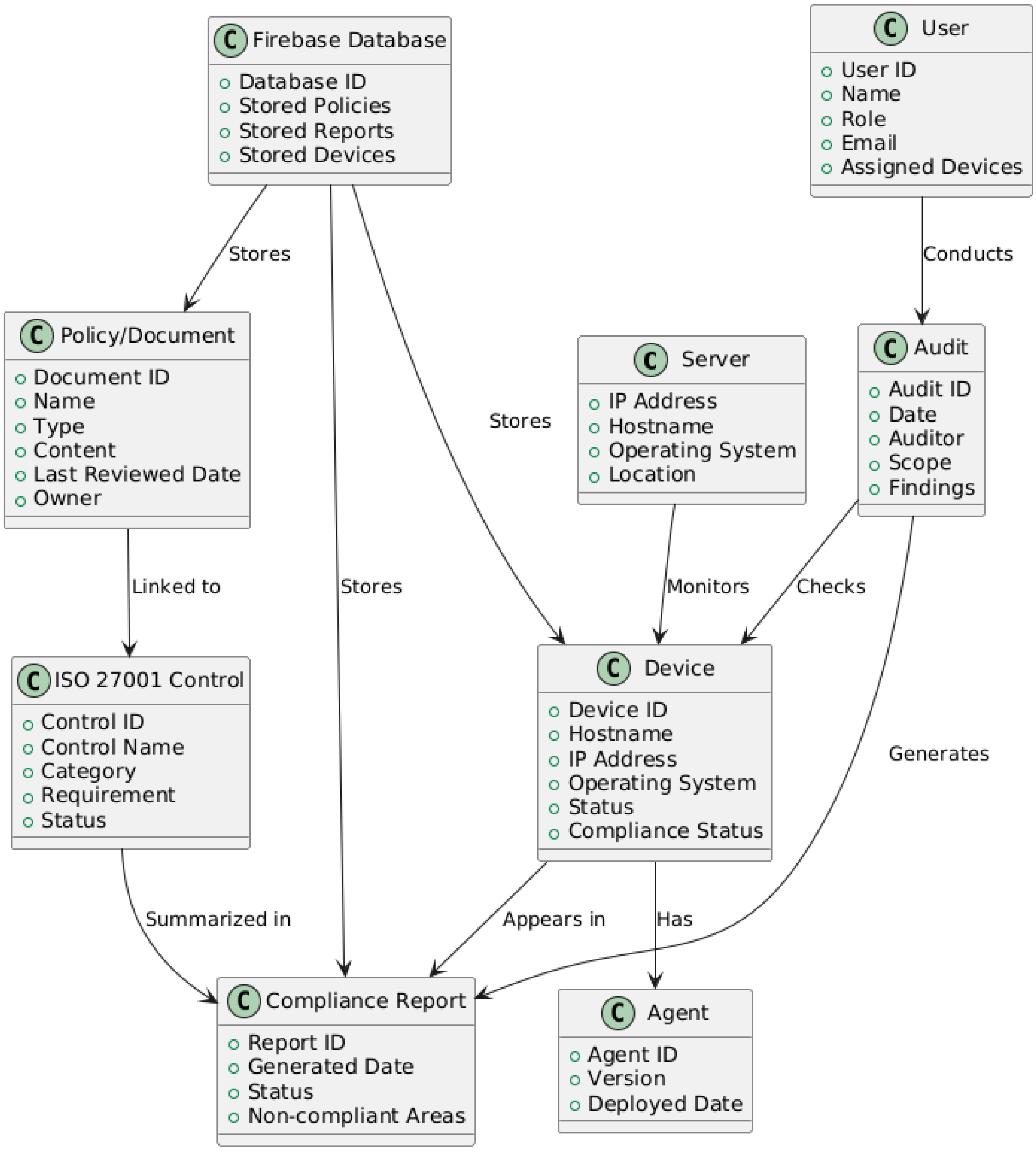
Our system would be very interactive and speedy. The performance requirements for the system outline the expected speed and efficiency of its various operations to ensure optimal user experience and functionality. Following are some examples of how our tool would have good performance efficiency: Example:

PER-1: 90PER-2: The system should allow for real-time data updates within 5 secs wait of request. PER-3: The application should take care of at least 50 users without interruption in performance.

2.3.4 Security

The security is very important for the good flow of our tool. The following requirements outline the measures taken for security implementation: SEC-1: All the data in the database will be encrypted. SEC-2: Role based access control would be applied on our tool within particular organization. SEC-3: The system will log all the activities happening within an organization.

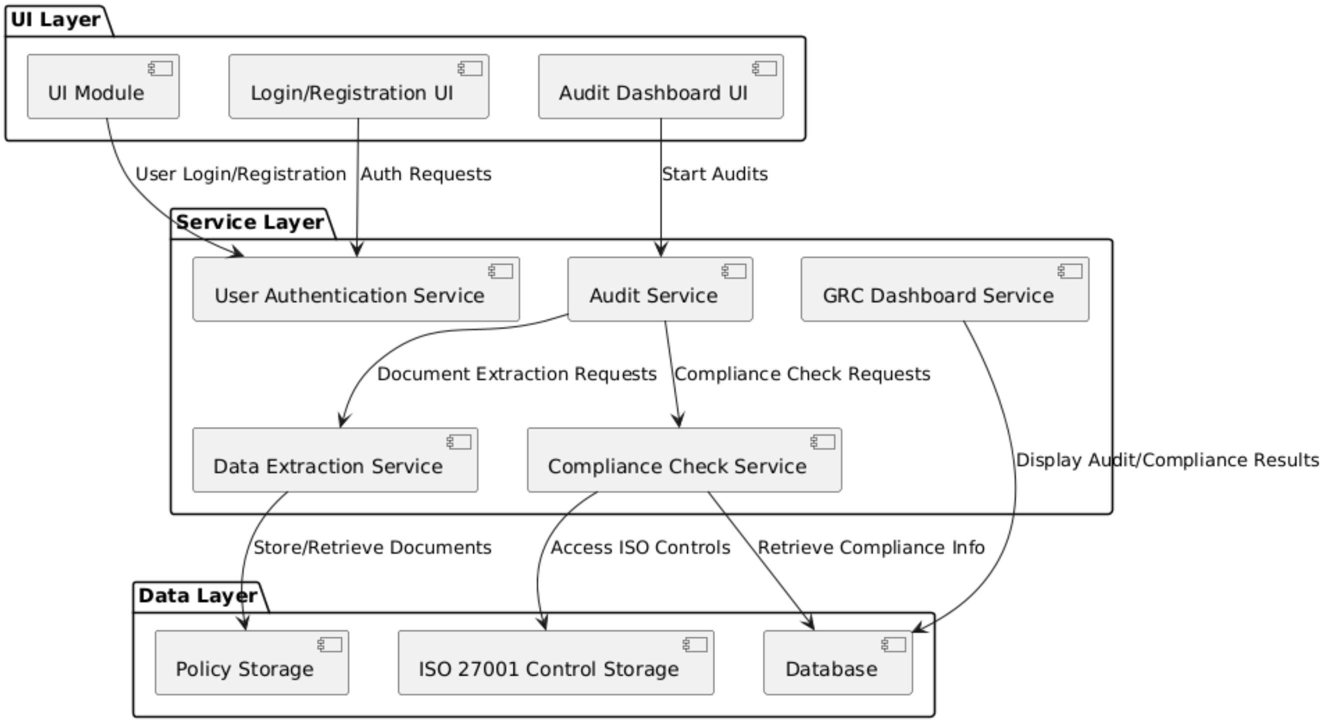
2.4 Domain Model



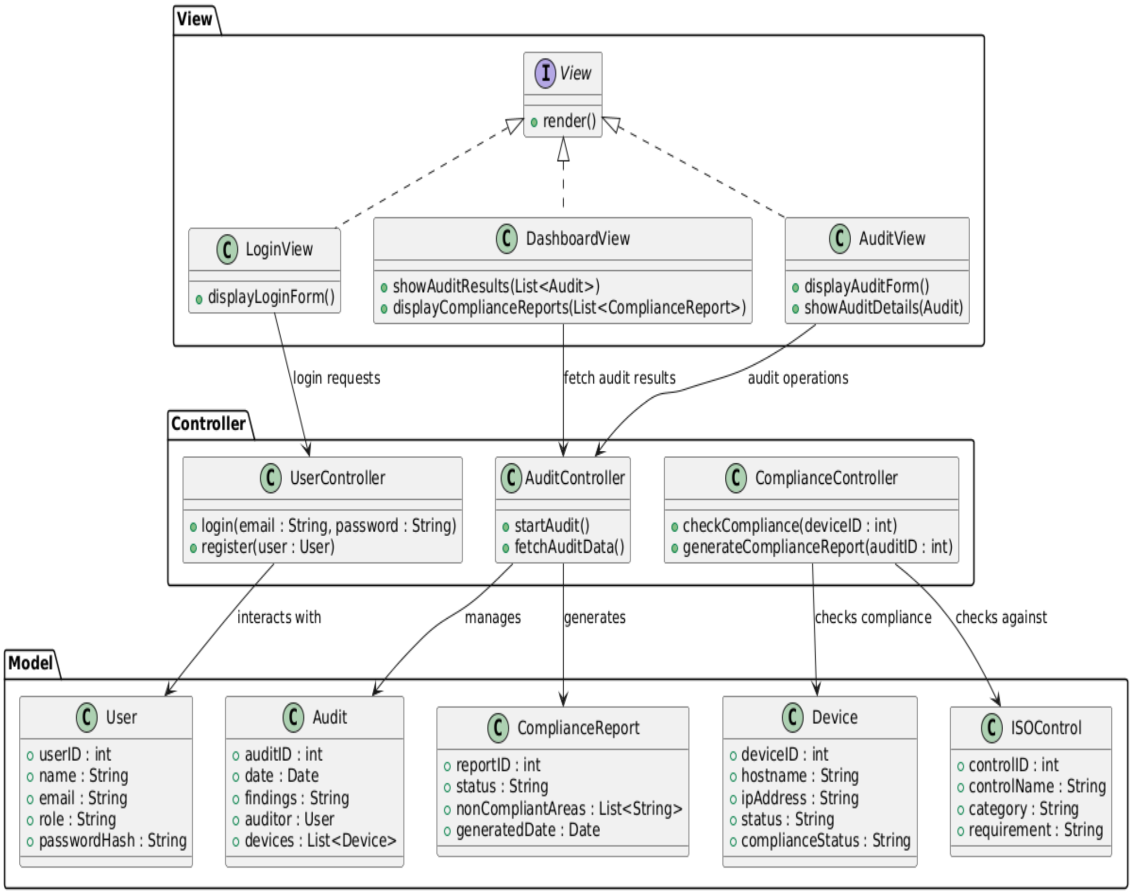
Chapter 3

System Overview

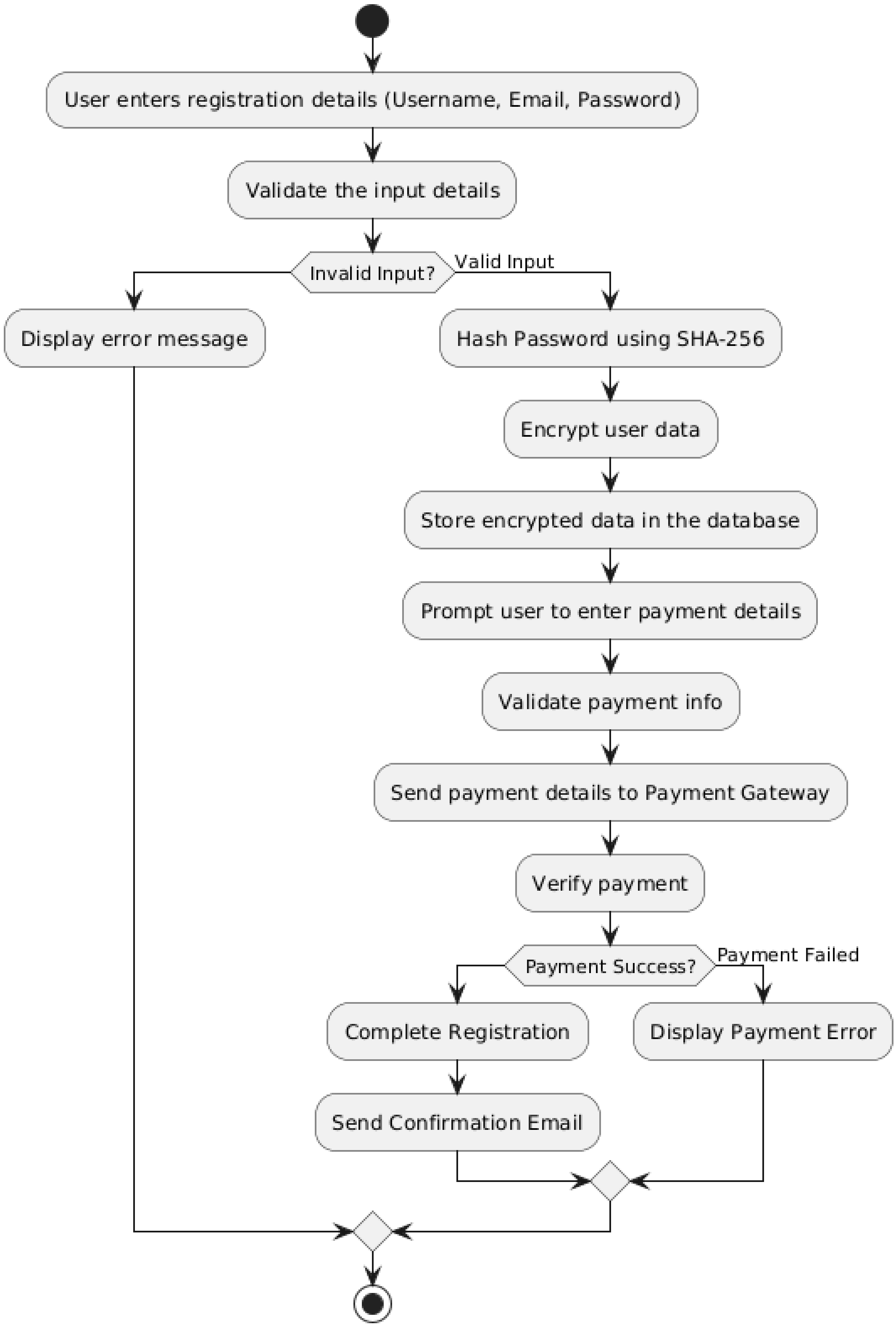
3.1 Architectural Design



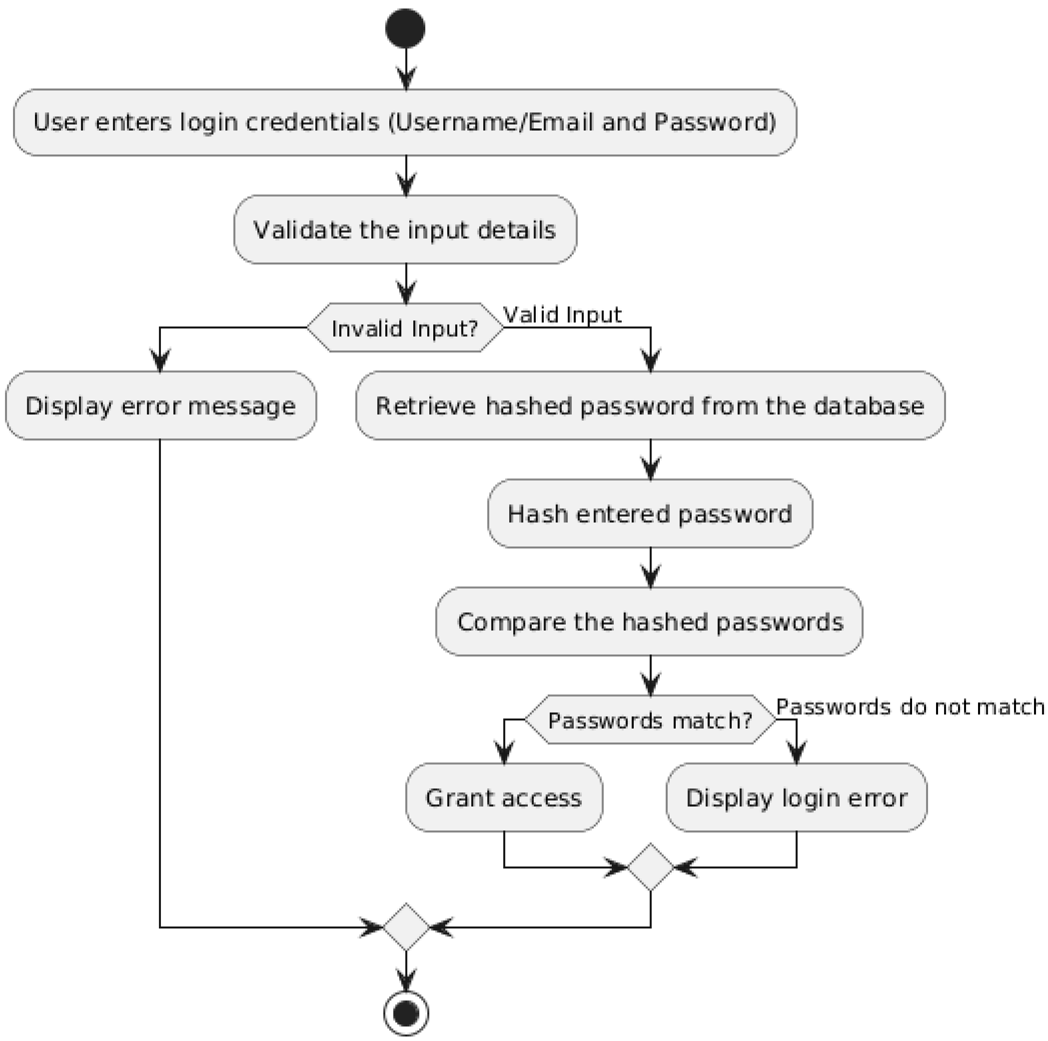
3.2.1 Design Models

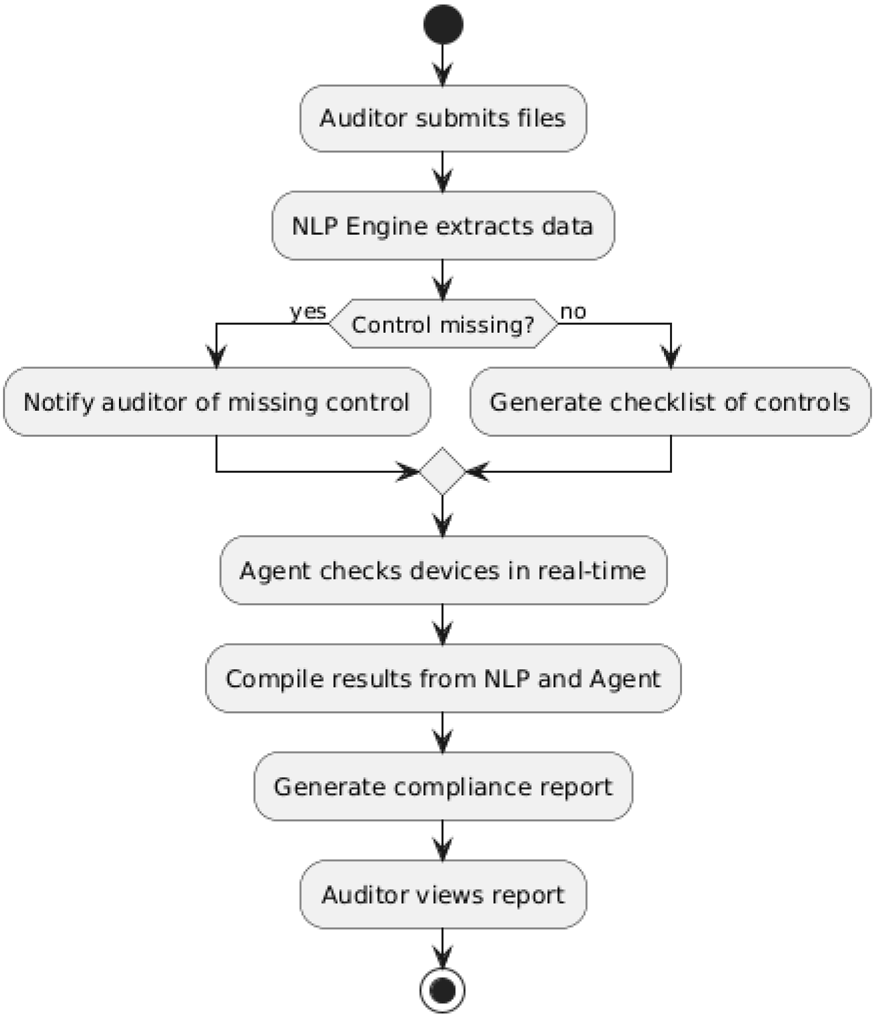


3.2.2 Activity diagram



Registration

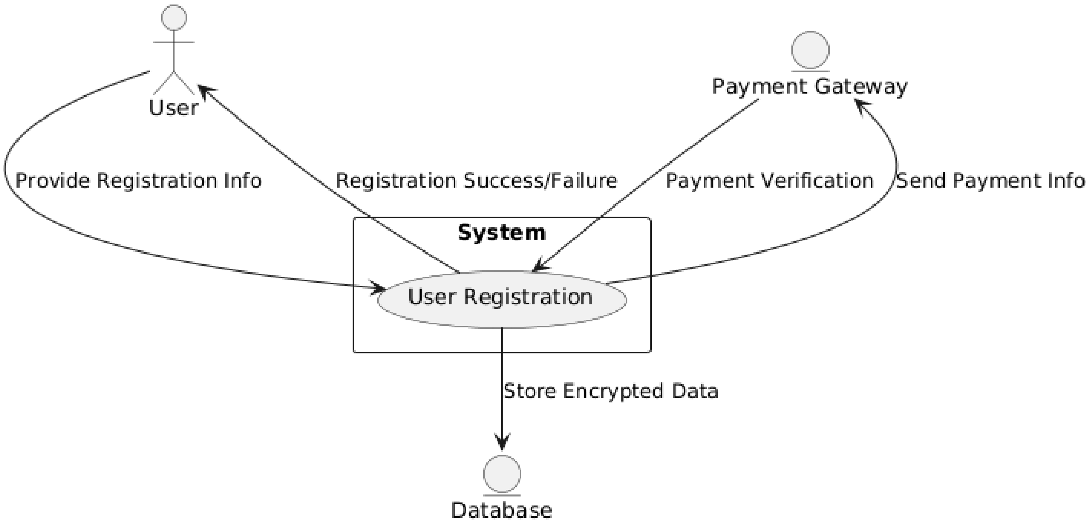

User enters login credentials (Username/Email and Password)
Validate the input details
Invalid Input?
Valid Input
Display error message
Retrieve hashed password from the database
Hash entered password
Compare the hashed passwords
Passwords match?
Passwords do not match
Grant access
Display login error


Auditor submits files
NLP Engine extracts data
Control missing?
yes
no
Notify auditor of missing control
Generate checklist of controls
Agent checks devices in real-time
Compile results from NLP and Agent
Generate compliance report
Auditor views report

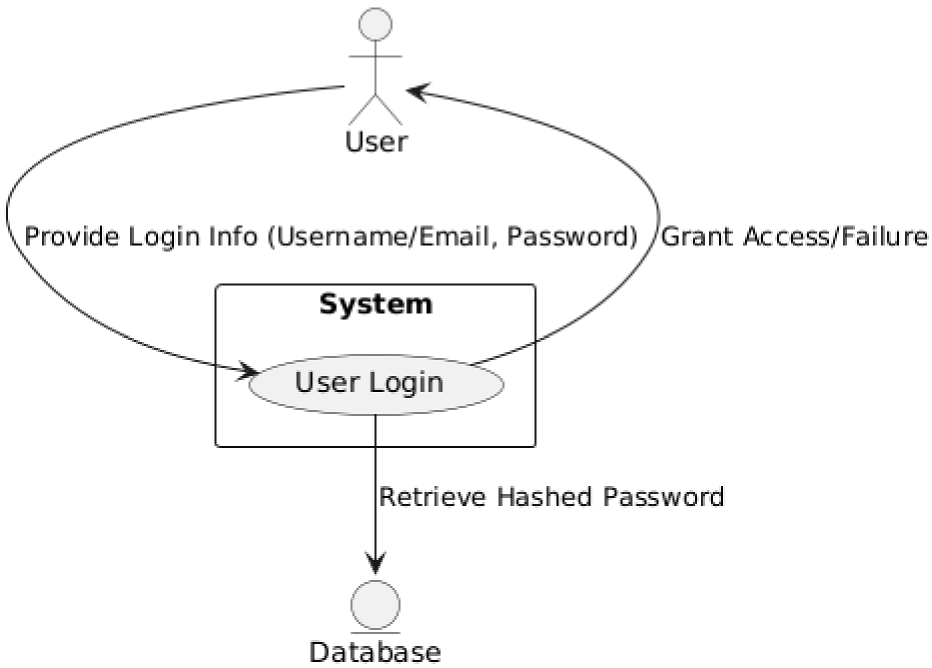
Scanner

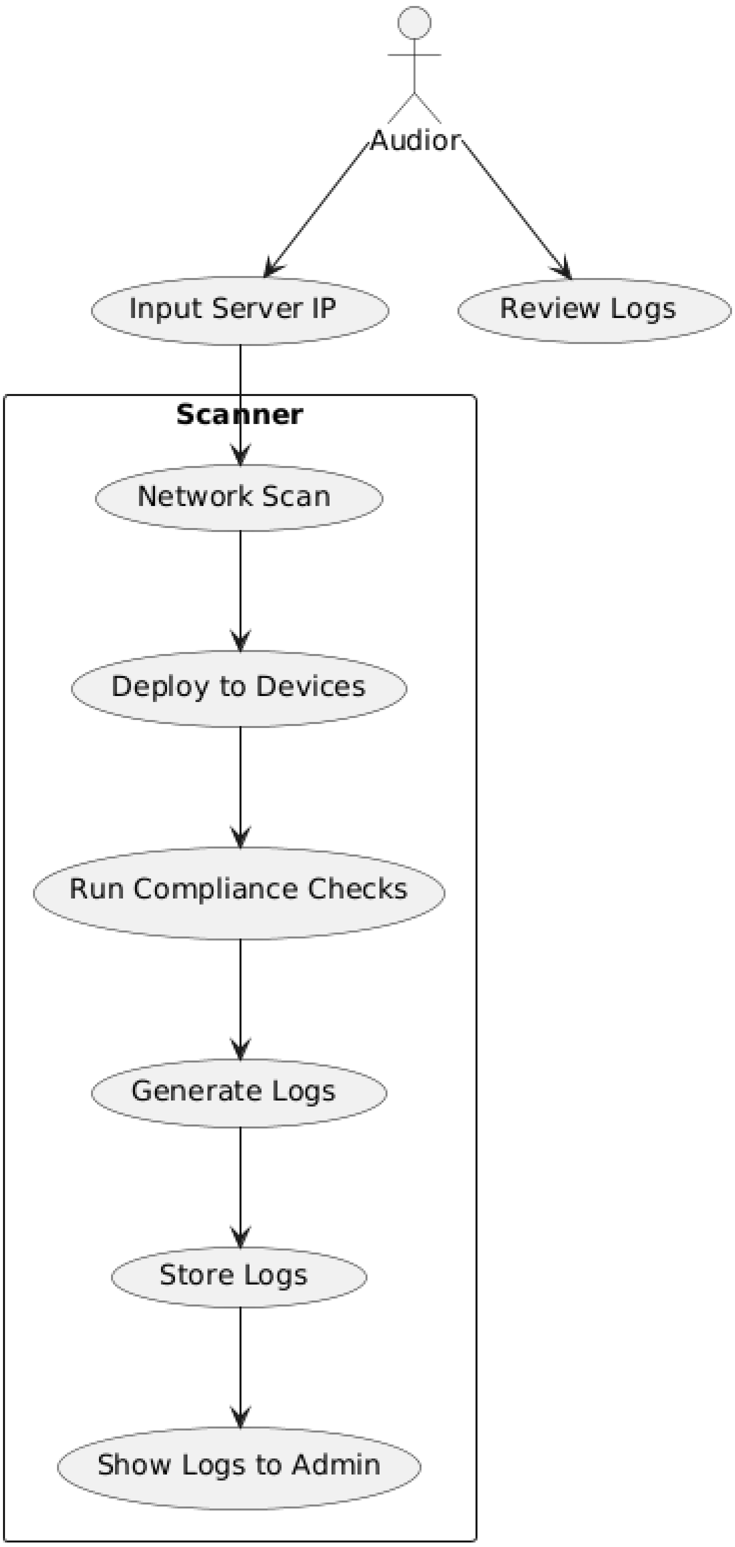
3.2.3 Data flow diagram

Level 0 Data Flow Diagram



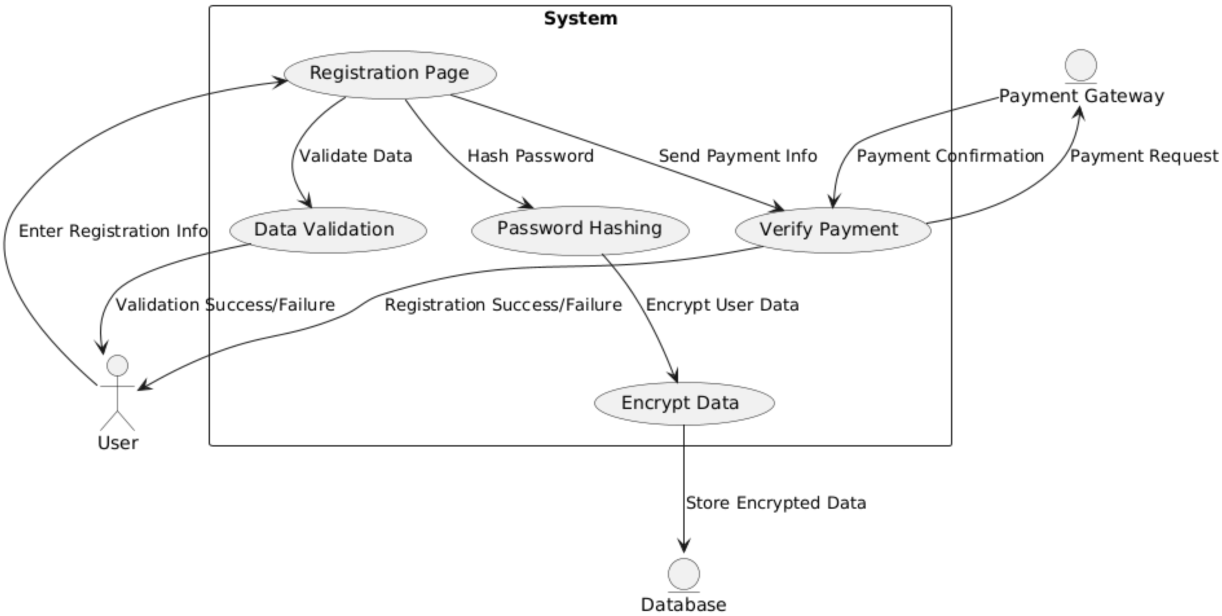
Registration



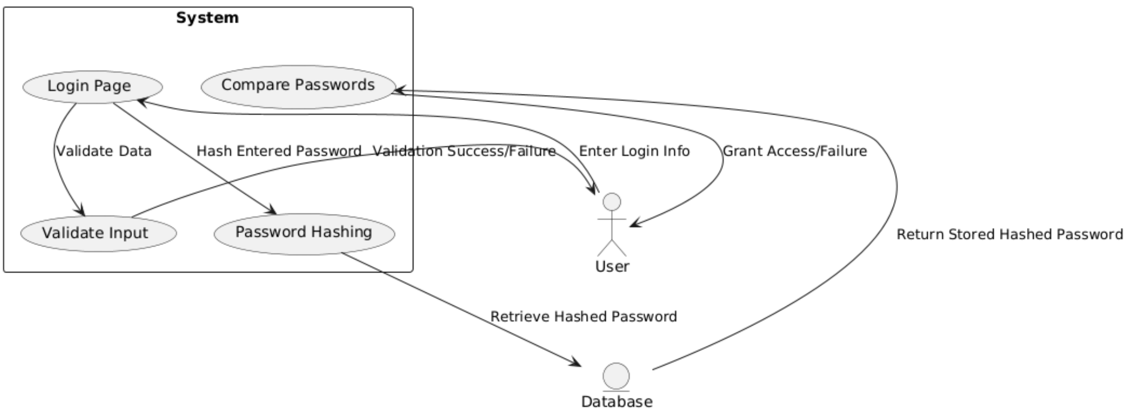

Audior
Input Server IP
Review Logs
Scanner
Network Scan
Deploy to Devices
Run Compliance Checks
Generate Logs
Store Logs
Show Logs to Admin

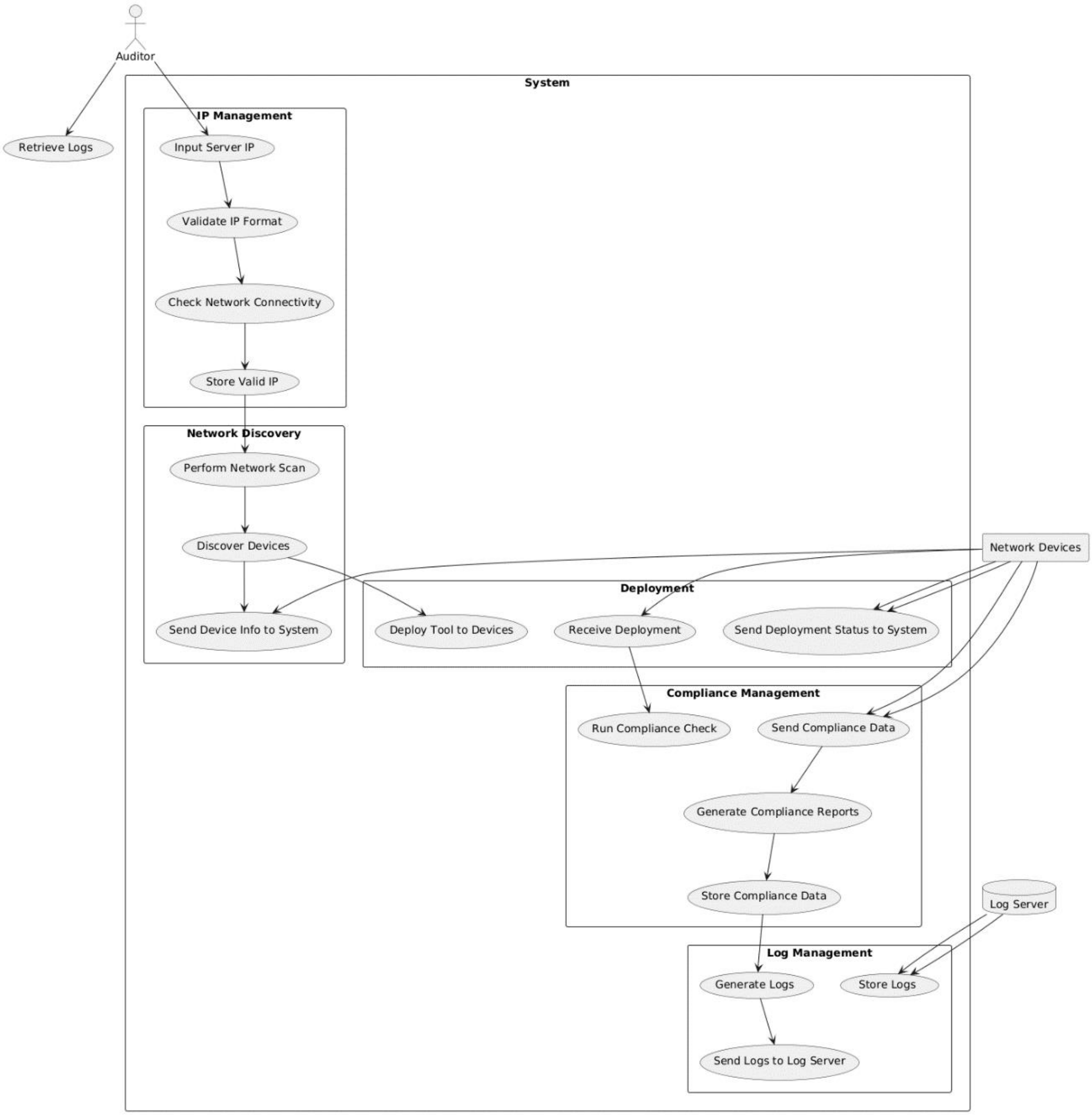
Scanner

Level 1 Data Flow Diagram



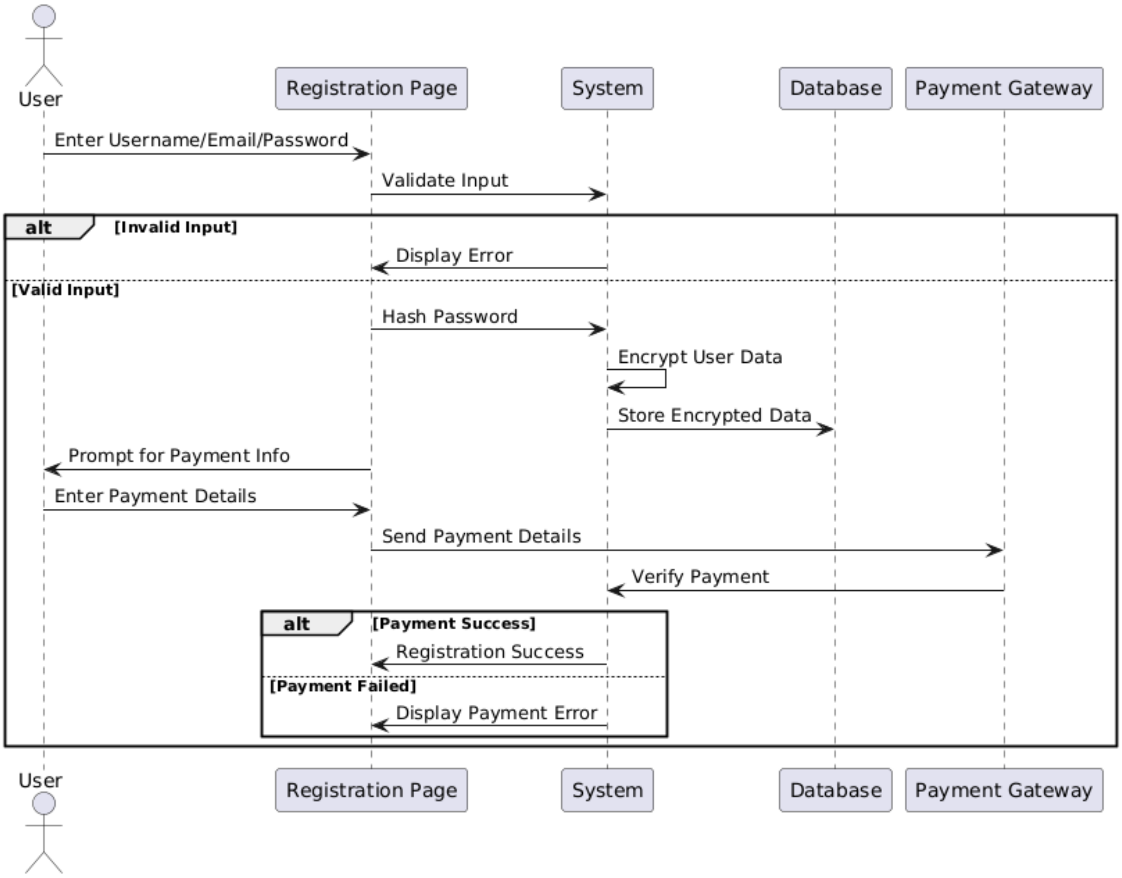
Registration

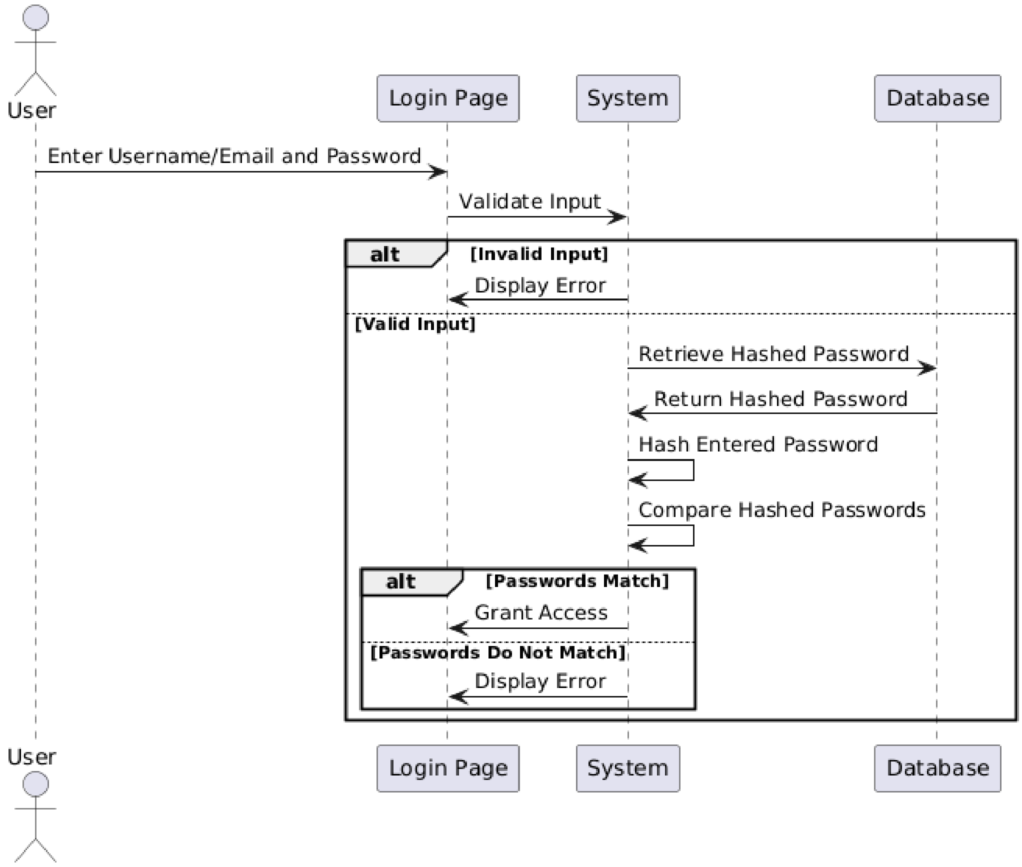


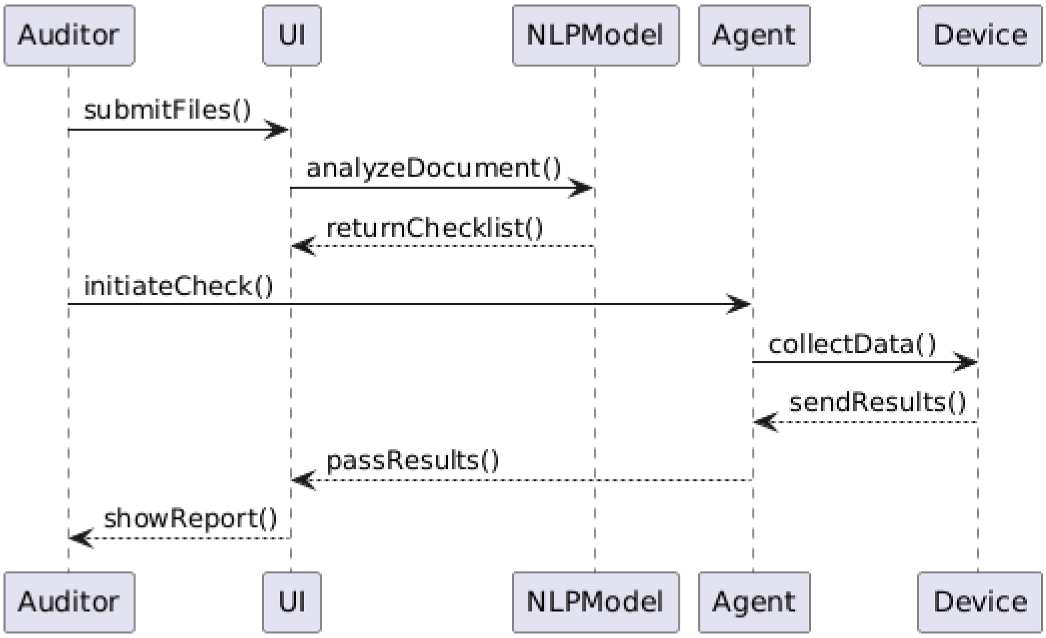

Auditor
Retrieve Logs
System
IP Management
Input Server IP
Validate IP Format
Check Network Connectivity
Store Valid IP
Network Discovery
Perform Network Scan
Discover Devices
Send Device Info to System
Deployment
Deploy Tool to Devices
Receive Deployment
Send Deployment Status to System
Network Devices
Compliance Management
Run Compliance Check
Send Compliance Data
Generate Compliance Reports
Store Compliance Data
Log Server
Log Management
Generate Logs
Store Logs
Send Logs to Log Server

Scanner

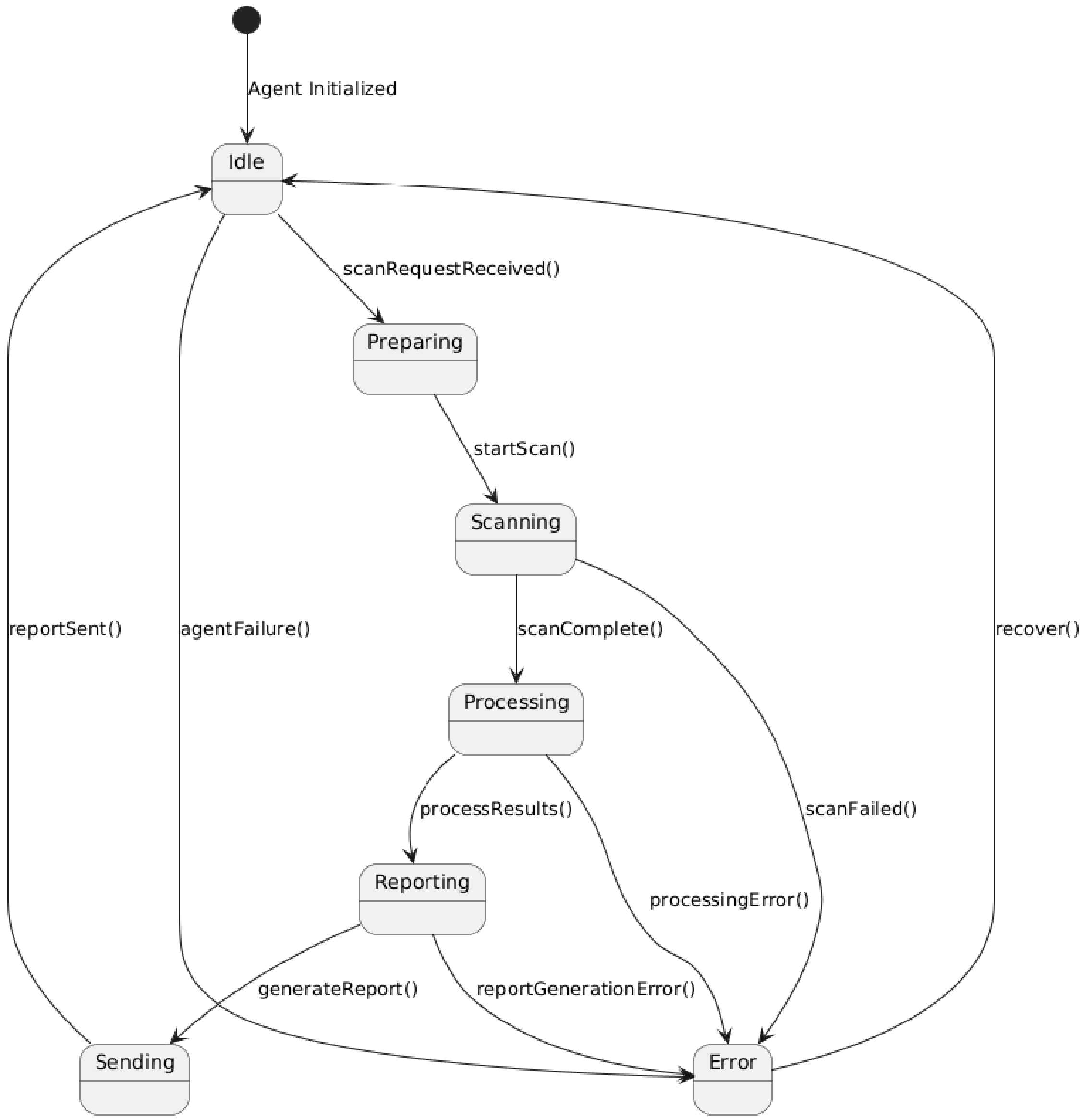
3.2.4 System Level Sequence Diagram

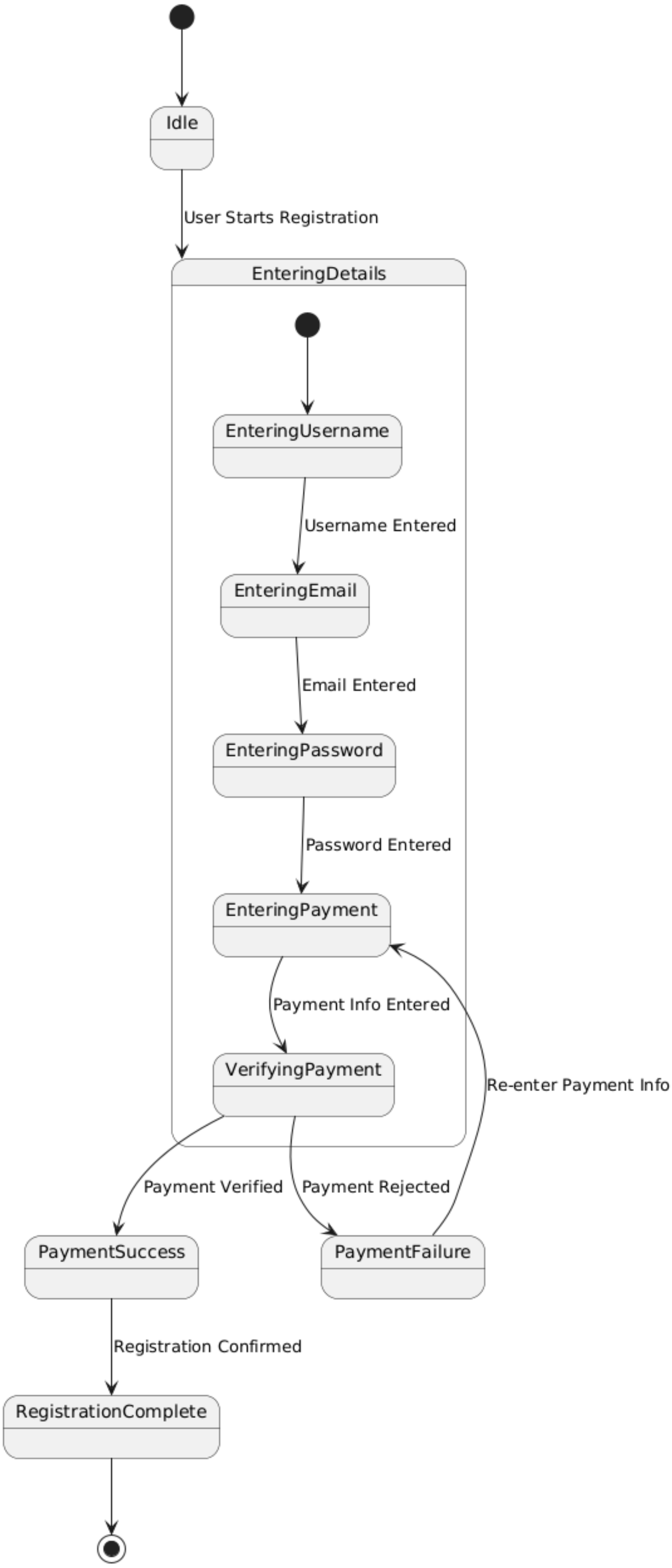


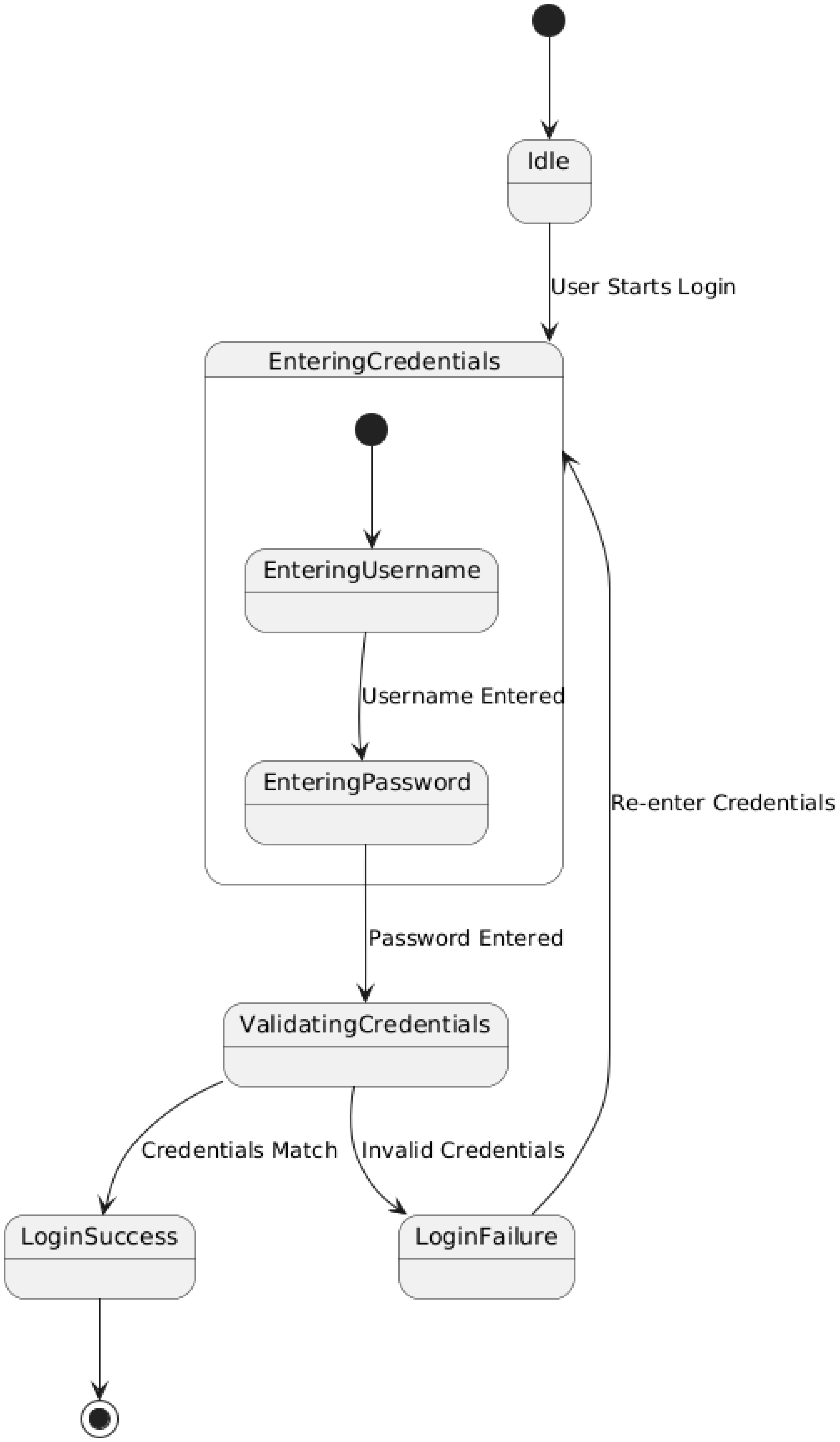

User
Login Page
System
Database
Enter Username/Email and Password
Validate Input
alt
[Invalid Input]
Display Error
[Valid Input]
Retrieve Hashed Password
Return Hashed Password
Hash Entered Password
Compare Hashed Passwords
alt
[Passwords Match]
Grant Access
[Passwords Do Not Match]
Display Error
User
Login Page
System
Database


Auditor
UI
NLPModel
Agent
Device
submitFiles()
analyzeDocument()
returnChecklist()
initiateCheck()
collectData()
sendResults()
passResults()
showReport()
Auditor
UI
NLPModel
Agent
Device

3.2.5 State transition diagram




Idle
User Starts Registration
EnteringDetails
EnteringUsername
Username Entered
EnteringEmail
Email Entered
EnteringPassword
Password Entered
EnteringPayment
Payment Info Entered
VerifyingPayment
Re-enter Payment Info
Payment Verified
Payment Rejected
PaymentSuccess
PaymentFailure
Registration Confirmed
RegistrationComplete


Idle
User Starts Login
EnteringCredentials
EnteringUsername
Username Entered
EnteringPassword
Re-enter Credentials
Password Entered
ValidatingCredentials
Credentials Match
Invalid Credentials
LoginSuccess
LoginFailure

3.3 Data Design

In our system, the transformation of the information domain into well-defined data structures enables efficient handling and processing of compliance and audit-related tasks.

1. Data Structures:
Key data entities such as compliance checklists, audit records, user profiles, and risk assessments are organized into suitable structures like lists, hash maps, and arrays. These structures allow for fast data retrieval, filtering, and analysis, especially during auditing and reporting. Relationships between these entities are maintained to reflect any hierarchy (e.g., audits linked to specific users or departments).

2. Data Storage:
The system uses **Firebase**, a NoSQL database, for real-time synchronization and storage of all major data entities, including compliance logs, audit trails, and user activities. Firebase collections and documents hold semi-structured and unstructured data that can be queried efficiently based on user roles, permissions, or specific criteria.

3. Data Processing:
The backend processes all data in real-time, responding to user inputs, updating compliance records, and generating necessary reports. The Flask web framework (Python) is used to manage requests, process incoming data, and ensure proper data formatting for the front-end interface. The data flows seamlessly between the front end and Firebase via APIs, enabling consistent and reliable data operations.

4. Storage Solutions:
- **Firebase Database:** Stores real-time data including user details, compliance logs, and audit records.
- **Local Storage:** Used for temporary session data to improve performance.
- **Cloud Storage:** Used for larger files like audit documents and compliance reports, ensuring easy access when needed.

This organized data structure ensures the system remains responsive, scalable, and capable of handling real-time updates and queries efficiently.

Bibliography

https://www.centraleyes.com/iso-27001-mandatory-documents/#:~:text=ISO%2027001%20Guide%20To%20Compliance&text=These%20

mandatory%20requirements%20include%20ISMS,of%20monitoring%2C%20and%20many%20more.